

Security+ 4.3 · Vulnerability Remediation

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 4.3** —
Vulnerability Remediation (8:45) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Vulnerability remediation includes patching (ideal), segmentation (isolating vulnerable systems), and compensating controls (e.g., virtual patching via firewall/IPS) when patching is not possible. MTTR (Mean Time to Remediate) is the key metric for vulnerability management teams.

High-Yield Core Concepts Tested on Exam

- Patching is the ideal remediation; compensating controls when patching is impossible
- Segmentation isolates vulnerable systems to limit exposure
- Virtual patching: firewall/IPS blocks exploit without touching the vulnerable system
- MTTR (Mean Time to Remediate): average time to fix vulnerabilities
- Legacy/ICS systems often require compensating controls

Exam Tips & Classic Scenarios

- 'blocks the exploit without touching the vulnerable system' = virtual patch
- 'isolates the vulnerable system from the rest of the network' = segmentation
- 'average time to remediate' = MTTR

Typical Exam Scenario: A factory system cannot be patched, so it is isolated and the firewall blocks the exploit, which is an example of a virtual patch/compensating control.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 4.3 — Vulnerability Remediation)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. Corporate scenario (Vulnerability Remediation): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.3), an analyst evaluates the following technical requirement: 'Patching ideal; compensating: when patching isn't possible (legacy ICS).' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Patching ideal; compensating: when patching isn't possible (legacy ICS).
- D)** Allow shared access among administrators using generic credentials

2. Corporate scenario (Vulnerability Remediation): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.3), an analyst evaluates the following technical requirement: 'MTTR: mean time to remediate — the team's metric.' What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: MTTR: mean time to remediate — the team's metric...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

3. Corporate scenario (Vulnerability Remediation): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.3), an analyst evaluates the following technical requirement: 'blocks the exploit without touching the vulnerable system'=virtual patch'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: 'blocks the exploit without touching the vulnerable system'=virtual patch...

4. Corporate scenario (Vulnerability Remediation): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.3), an analyst evaluates the following technical requirement: 'factory system without patch: isolated and firewall blocks the exploit' = virtual patch/compensating control. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'factory system without patch: isolated and firewall blocks the exploit' = virtual patch/compensating control
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

5. Corporate scenario (Vulnerability Remediation): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.3), an analyst evaluates the following technical requirement: 'Patching ideal; compensating: when patching is not possible (legacy ICS)'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Patching ideal; compensating: when patching is not possible (legacy ICS)
- D)** Allow shared access among administrators with generic credentials

6. Corporate scenario (Vulnerability Remediation): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.3), an analyst evaluates the following technical requirement: 'MTTR: mean time to remediation — the team's metric'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: MTTR: mean time to remediation — the team's metric...
- D)** Allow shared access among administrators with generic credentials

7. Corporate scenario (Vulnerability Remediation): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.3), an analyst evaluates the following technical requirement: 'blocks the exploit without touching the vulnerable system'=virtual patch'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'blocks the exploit without touching the vulnerable system'=virtual patch...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

8. Corporate scenario (Vulnerability Remediation): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.3), an analyst evaluates the following technical requirement: 'factory system without patch: isolated and the firewall blocks the exploit' = virtual patch/compensating. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'factory system without patch: isolated and the firewall blocks the exploit' = virtual patch/compensating...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

9. Corporate scenario (Vulnerability Remediation): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.3), an analyst evaluates the following technical requirement: 'Patching ideal; compensating: when patching is not possible (legacy ICS).' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Patching ideal; compensating: when patching is not possible (legacy ICS)...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

10. Corporate scenario (Vulnerability Remediation): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.3), an analyst evaluates the following technical requirement: 'MTTR: mean time to remediation — the team's metric'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: MTTR: mean time to remediation — the team's metric.

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) C — Implement the corresponding solution: Patching ideal; compensating: when patching isn't possible (legacy ICS)..

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.3 (Vulnerability Remediation): Patching ideal; compensating: when patching isn't possible (legacy ICS). Patching is the ideal remediation, but when it's not feasible (e.g., legacy industrial control systems), compensating controls such as network segmentation, strict access controls, and monitoring should be implemented. The best recommendation is to apply compensating controls when patching is not possible.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detect incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

2) A — Implement the corresponding solution: MTTR: mean time to remediate — the team's metric....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.3 (Vulnerability Remediation): MTTR: mean time to remediate — the team's metric.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

3) D — Implement the corresponding solution: 'blocks the exploit without touching the vulnerable system'=virtual patch....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.3 (Vulnerability Remediation): 'blocks the exploit without touching the vulnerable system'=virtual patch. A virtual patch is a security control that mitigates a vulnerability by intercepting and blocking exploit attempts at the network or host level (e.g., via IPS, WAF, or endpoint protection) without modifying the vulnerable software itself. This is especially useful when a vendor patch is unavailable or cannot be applied immediately.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks

compliance standards (PCI DSS, ISO 27001).

- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

4) A — Implement the corresponding solution: 'factory system without patch: isolated and firewall blocks the exploit' = virtual patch/compensating control.

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.3 (Vulnerability Remediation): 'factory system without patch: isolated and firewall blocks the exploit' = virtual patch/compensating control. A virtual patch is a compensating control that mitigates a vulnerability without modifying the underlying system—often used when a system cannot be patched (e.g., legacy or factory systems). Isolating the system and using firewall rules to block the exploit is a classic example of a compensating control.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and it breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

5) C — Implement the corresponding solution: Patching ideal; compensating: when patching is not possible (legacy ICS).

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.3 (Vulnerability Remediation): Patching ideal; compensating: when patching is not possible (legacy ICS).

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

6) C — Implement the corresponding solution: MTTR: mean time to remediation — the team's metric....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.3 (Vulnerability Remediation): MTTR: mean time to remediation — the team's metric. MTTR measures the average time taken to remediate vulnerabilities and is a key performance indicator for the security team's efficiency.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

7) B — Implement the corresponding solution: 'blocks the exploit without touching the vulnerable system'=virtual patch....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.3 (Vulnerability Remediation): 'blocks the exploit without touching the vulnerable system'=virtual patch. A virtual patch is a security measure that mitigates a vulnerability by intercepting and blocking exploits at the network or host level without modifying the vulnerable software itself. This is often used when a patch cannot be applied immediately.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting principle and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

8) B — Implement the corresponding solution: 'factory system without patch: isolated and the firewall blocks the exploit' = virtual patch/compensating....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.3 (Vulnerability Remediation): 'factory system without patch: isolated and the firewall blocks the exploit' = virtual patch/compensating. A virtual patch is a compensating control that mitigates a vulnerability when a vendor patch cannot be applied, often by using an IPS, WAF, or firewall rule to block the exploit. In this scenario, isolating the unpatched system and blocking the exploit at the firewall is a classic example of a compensating control (virtual patching).

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detect incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials*: This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

9) B — Implement the corresponding solution: Patching ideal; compensating: when patching is not possible (legacy ICS)....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.3 (Vulnerability Remediation): Patching is the ideal remediation for known vulnerabilities. When patching is not feasible (e.g., legacy ICS/SCADA systems), compensating controls such as network segmentation, virtual patching, or strict access controls must be implemented to mitigate risk.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

10) D — Implement the corresponding solution: MTTR: mean time to remediation — the team's metric..

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.3 (Vulnerability Remediation): MTTR: mean time to remediation — the team's metric. MTTR is a key performance indicator for remediation efficiency; the appropriate control is to implement the corresponding solution, such as tracking and optimizing MTTR through automated patching and incident response processes.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.